



第1回 サイバーリスク

(授業の補助資料)

面 和成



本講義の内容

- サイバー空間
- 不正アクセス
- 権限奪取
 - パスワードクラック
 - バッファオーバーフロー
- マルウェア
- サービス停止攻撃
- ウェブの脅威
- 組織内ネットワークにおける脅威
- その他の脅威



サイバー空間

- IPアドレス

- IPネットワークにおける住所
- 例：130.158.103.1（IPv4の場合，4バイト）

- ドメイン名

- IPネットワークに接続されたコンピュータの住所
- 例：risk.tsukuba.ac.jp

- ホスト名

- IPネットワークに接続されたコンピュータの名前
- 例：www（wwwは慣習的に使用されている）

- ポート番号

- IPネットワーク通信においてプログラムを識別するための番号
- 例：HTTPは80/tcp，HTTPSは443/tcp

FQDN

https://www.risk.tsukuba.ac.jp

 └───┬───┘

 ホスト名 ドメイン名

omote@risk.tsukuba.ac.jp

 └───┬───┘

 ドメイン名

IPアドレス

- IPネットワークにおける住所に相当
- IPアドレス（IPv4の場合）表記
 - 8ビット単位で4つに区切ったものを10進数表記（e.g., 192.168.1.1）
 - ネットワークアドレスとホストアドレスに分けられる
 - ネットワークアドレスが先頭から24ビットの場合：
 - ・ ネットワークアドレス：192.168.1.0/24
 - ・ サブネットマスク：255.255.255.0
 - ポート番号と一緒に書く場合もある
 - ・ 192.168.1.1:80
- グローバルIPアドレス
 - インターネット（WAN）で利用されるIPアドレス
- プライベートIPアドレス（ローカルIPアドレス）
 - イントラネット（LAN）で利用されるIPアドレス

Windows PowerShellでは
下記コマンドでIPアドレス
が表示される

```
ipconfig  
netstat -n
```



一般的な不正アクセスの手順



- (1) 事前処理
 - ポートスキャン
 - ターゲットの脆弱性等の調査
 - ・ サーバのOSやソフトウェアの種類・バージョンなどを調べる
- (2) 権限奪取
 - 脆弱性の利用やパスワード等の不正入手によってサーバ等の利用権限を奪取
- (3) 攻撃実行
 - クラッカーによるデータの盗難, 消去, 踏み台のための不正プログラムのインストール
- (4) 撤収処理
 - 不正に侵入した痕跡を消去
 - バックドアの埋め込み

Q. なぜ？



不正アクセスのシナリオ

- (1) 標的型のサイバー脅威

- 情報資産の多いコンピュータを狙い撃ちする攻撃
- 情報資産の窃取が主な狙い
- 高度な技術で侵入を試みる
- ソーシャルエンジニアリングを駆使し、事前処理に時間をかける
- e.g., コインチェック事件

- (2) 無差別型のサイバー脅威

- 脆弱性のあるコンピュータを数多く狙う攻撃
- Botnetの形成が主な狙い
- ロボットプログラム（マルウェア）を利用して機械的に侵入を試みる
- スキャンしながらターゲットを探す
- e.g., Miraiボットネット（数十万～数百万台）



パスワードクラック

- 不正な技術的手段によって、パスワードまたはIDとパスワードの組み合わせを突き止めようとする攻撃
- オンラインでのパスワードクラック
 - ネットワークに接続されたサーバに対してログインを試みる
 - 多数回の不審なアクセスがあれば、サーバ側で検知して対応措置可能
- オフラインでのパスワードクラック
 - 入手したデータを手元で解析してパスワードを突き止めようとする
 - パスワードで保護された文書ファイル（wordやPDF等）などが対象
 - 一度このファイルが手元にくるとオフライン状態になるため、ローカルでパスワードクラックが可能になる。

Q. 具体例は？



パスワードクラックの攻撃目標と具体的な手法

● パスワードを探し出すための具体的な手法

□ 総当たり攻撃 (brute force attack)

- あらゆる文字列を用いて手当たり次第にログインを試みる
- 8桁の数字であれば, 00000000から99999999までの全てを試す

□ 辞書攻撃 (dictionary attack)

- 人間は記憶しにくいランダム列よりも覚えやすい文字列を使うことが多い
- 辞書に載っている単語や人名, それを逆順にした文字列などを利用
- 攻撃者が事前に入手したIDとパスワードのリストを利用するパスワードリスト攻撃 (list-based attack) もこの一種

□ 統計的攻撃 (statistical attack)

- パスワードの構造を統計的に分析したものを利用
- 過去に流出した数千万件のパスワードについて構造を解析
例えば, 大文字や数字, 記号の位置, 同じ文字種の連続など

パスワードクラックツール

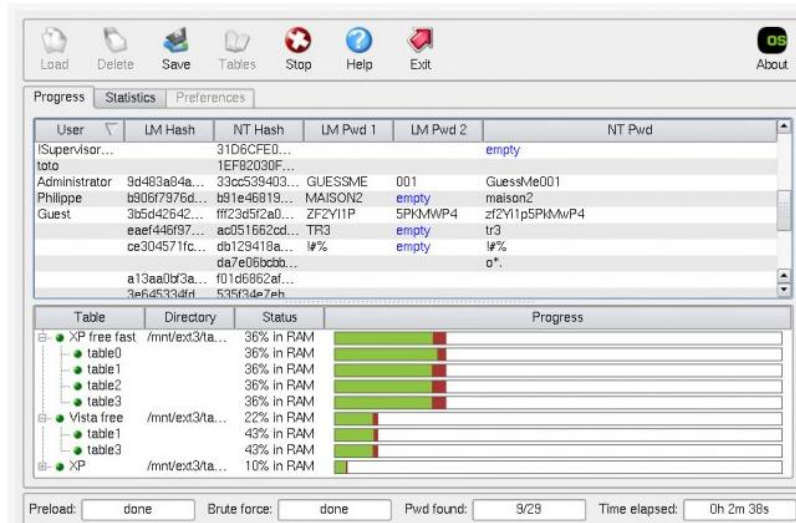
● ophcrack LiveCD

- Windows XP/Vista/7 のパスワードを探し出す
- メモリ上に専用のOSが起動する（1CD Linux と同じ）
- Windowsにログインしなくてもクラック可能
- レインボーテーブルを使用して Windows LM hashes を解析

● クラック実験

- 14桁パスワード（大文字小文字混合，数字）が2分54秒でクラック
 - Let's note（WindowsXP）
 - CPU:Core2 Duo 1.06GHz
 - メモリ:2GB

Q. 対策は？

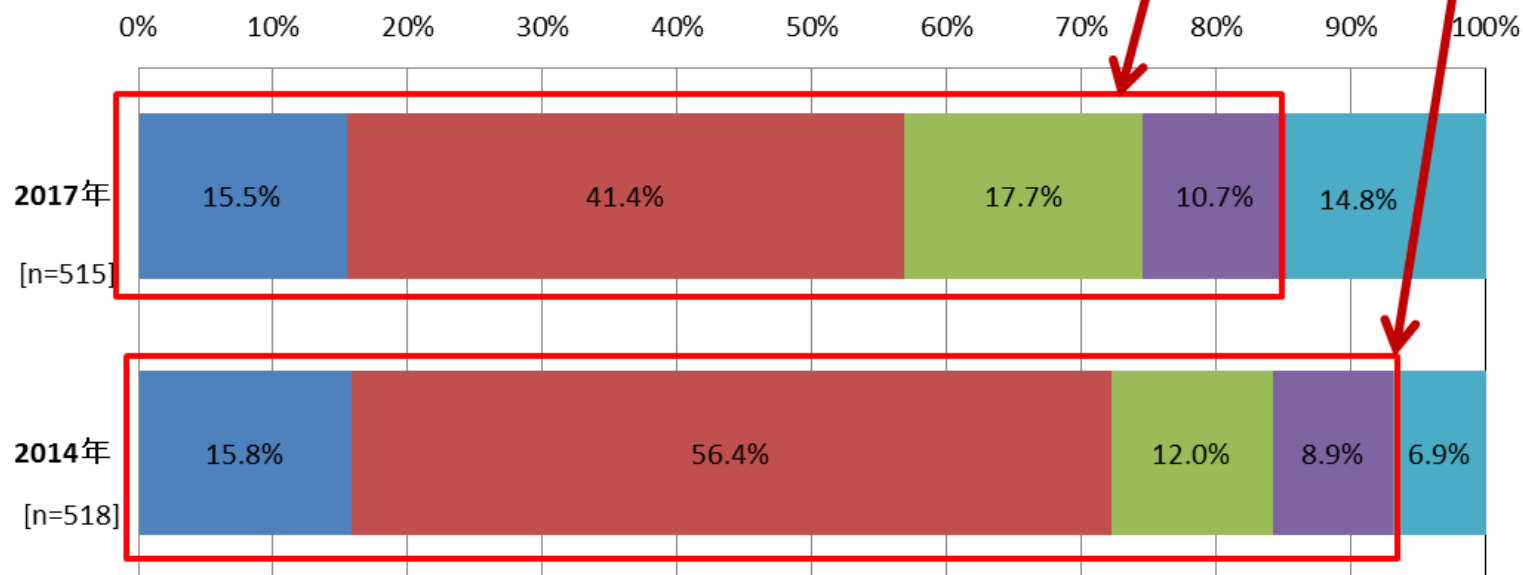


パスワードクラックの2次被害

- 1種類のパスワードでほぼ全てのWebサービスを利用している
- 2-3種類のパスワードでほぼ全てのWebサービスを利用している
- 4-5種類のパスワードでほぼ全てのWebサービスを利用している
- 6種類以上のパスワードでほぼ全てのWebサービスを利用している
- 利用する全てのWebサービスで異なるパスワードを設定している

Q. どんなリスクがある？

使いまわしをしている

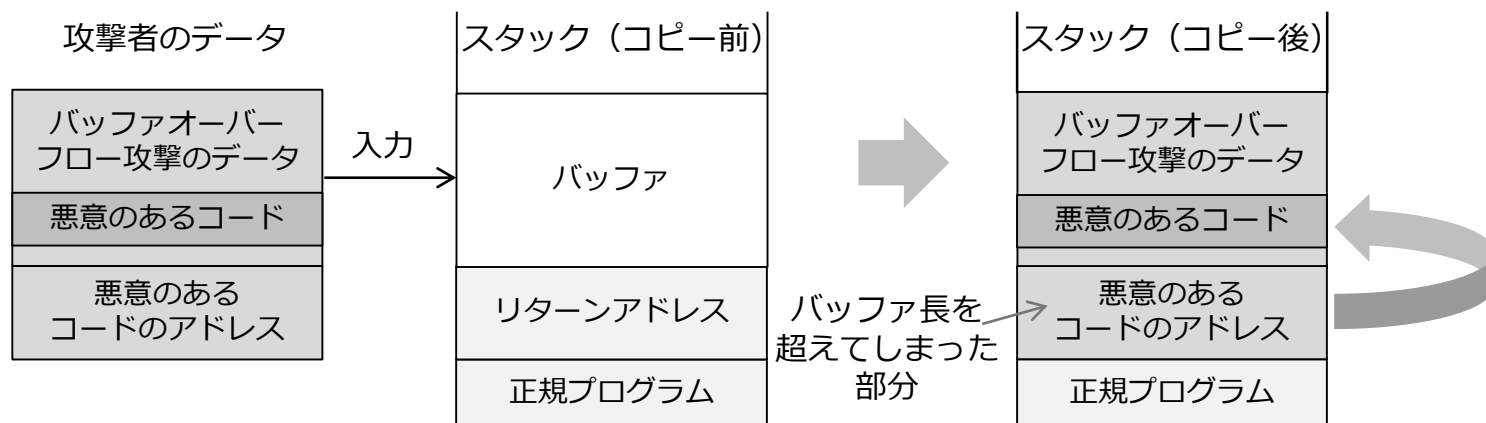


パスワードの使い回しの実態（トレンドマイクロ調査）



バッファオーバーフロー

- アプリケーションのバグ等を利用して、確保されたバッファを超えてデータを書き込むことで、不正なプログラムを実行



- C言語特有の問題

- gets, strcpy, strcat は、バッファ長のチェックを行わないため、バッファオーバーフローによる不正動作の危険性がある
- fgets, strncpy, strncat は、バッファのサイズを渡すことができるのでバッファオーバーフローは起きない



具体的なバッファオーバーフローの簡単なコード例

パスワード認証を行うプログラム

標準入力の文字列を
16バイトのバッファに
コピー

```
#include<stdio.h>
#include<string.h>
```

```
int check(char *pass){
    int accept = 0;
    char pass_buffer[16];
    strcpy(pass_buffer, pass);
    if (strcmp(pass_buffer, "1234") == 0)
        accept = 1;
    return accept;
}
```

標準入力の文字列が
16バイトを超えたら
acceptが上書きされる

```
int main(int argc, char *argv[]){
    if (argc < 2){
        printf("usage: %s <password>¥n", argv[0]);
        exit(0);
    }
    if (check(argv[1])) {
        printf("OK¥n");
    } else {
        printf("NG¥n");
    }
}
```



マルウェア

- 「Malicious Software」の略であり、不正かつ有害な動作を行う意図で作成された悪意あるソフトウェアの総称
- 感染被害
 - （被害者）感染端末にあるファイルの漏洩・改ざん・削除
 - （加害者）DDoS攻撃やスパムメールの送信
- 亜種が活発化
 - パターンマッチングの回避が可能
 - 作成が容易（マルウェアの亜種を作成できるツールの出現）
- C&Cサーバ（Control and Command Server）
 - 踏み台のコンピュータを遠隔操作するサーバ
- 難読化テクニック
 - メタモフィック（コードの改変）
 - ポリモフィック（コードの暗号化）



特徴的なマルウェア

- ボットネット (Botnet)

- ボットと呼ばれるマルウェアに感染したインターネット上の大量のコンピュータ群からなるネットワーク
- 1台のPCから数百台～数百万台のコンピュータへ指令 (DDoS, スパム送信, ストレージ, 代理計算など) を出すことが可能

Q. 代理計算とは？

- RAT (Remote Access Trojan)

- 遠隔操作が可能となるトロイの木馬型のマルウェア
- ファイアウォールを超えて, 組織内の感染PCとインターネット側の攻撃者が繋がる

- ランサムウェア (Ransomware)

- パソコン内のファイルを暗号化して使用不能にする
- 復号するための秘密鍵と引き替えに身代金の振り込みを要求
 - 暗号資産との相性がよい
- クラウドストレージ上にある共有ファイルやバックアップファイルも暗号化される

Q. なぜか？



RAT

● 遠隔操作ウイルスのこと

- Poison Ivy, Gh0st, Cerberus, ...

● 特徴

- 密かにターゲットPCに潜伏して機密情報の撮取をねらう
- 遠隔操作機能

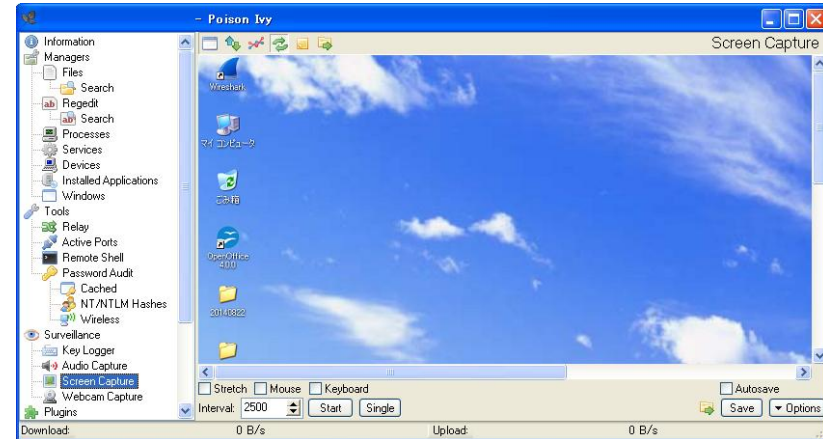
- ・ ファイルの閲覧, ダウンロード, アップロード, ...
- ・ キーロガー, スクリーンキャプチャ, ...

- 侵入を完全に防ぐのが困難

● 活動隠蔽の傾向 出典：国内標的型サイバー攻撃分析レポート 2019年版

Q. なぜ暗号化されていないHTTPの方が多いのか？

- C&C通信：HTTPが60%, HTTPSが40% (2018年の結果)
- DLLプリロード：正規プロセスへの寄生. 表面上は正規ファイルのプロセスが実行されているだけに見える
- ファイルレス活動：マルウェア本体を端末内に保存しない



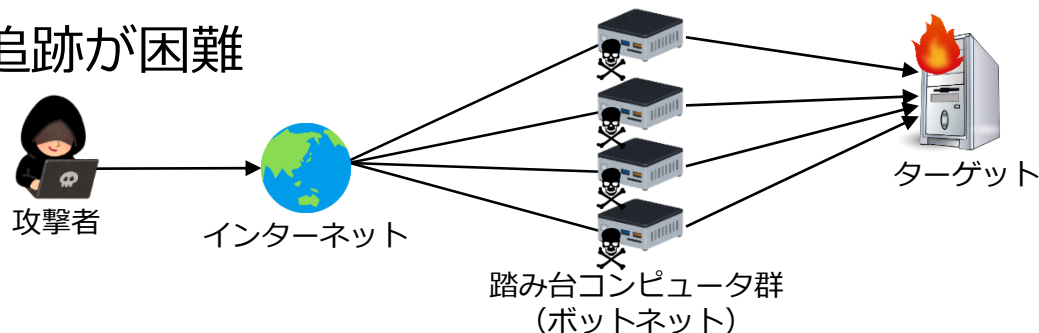
IPスプーフィング

- IPヘッダ内の送信元IPアドレスを偽装すること
- メールアドレスの偽装が容易であるのと同様に, IPアドレスの偽装も容易
- 他の攻撃を実行する手段の一部として使われる
- IPスプーフィングの例
 - 1. 攻撃者の身元隠蔽
 - 2. 送信元のなりすまし
 - 3. アクセス許可されている送信元IPアドレスを付与
 - 4. パケット毎に異なる送信元IPアドレスを付与
 - 5. 標的コンピュータのIPアドレスを送信元に設定



サービス停止攻撃 (1/2)

- Webサーバや通信機器などに意図的に過剰な負荷をかけたり脆弱性をついたりする事でサービスを妨害する攻撃
- DoS (Denial of Service) 攻撃
 - 過負荷をかけるもの
 - SynFlood攻撃, ホームページへの異常な数のアクセスなど
 - サーバ等が提供するプログラムの脆弱性を突くもの
 - 1パケットでサービスが落ちてしまう場合もある
- DDoS (Distributed Denial of Service) 攻撃
 - 多数の無関係なコンピュータを乗っ取り, それらを踏み台にして一斉にターゲットへ大量のトラフィックを送る
 - 黒幕である攻撃者の追跡が困難
 - 防御が困難 Q. なぜ?



サービス停止攻撃 (2/2)

- DRDoS (Distributed Reflection DoS) 攻撃

- 送信元IPアドレスを攻撃ターゲットのIPアドレスに偽装
- パケットを多数のコンピュータに反射させて、大量のパケットを攻撃ターゲットに集中させるDDoS攻撃
 - この「多数のコンピュータ」を乗っ取る必要がない
- 増幅攻撃になっていると被害が深刻になる
 - NTPの脆弱性を悪用したDRDoS攻撃では、リクエストサイズに対して数十倍から数百倍のサイズのレスポンスが返った

- Slow HTTP DoS 攻撃

- サーバが同時に処理できるリクエスト数を飽和させる攻撃
- パケットの通信間隔を長くすることでコネクションを長時間占有
- 必ずしも大量のトラフィックを必要としない
 - 攻撃者にとっては低コストで攻撃が可能
 - ターゲットにとっては攻撃の検知が困難

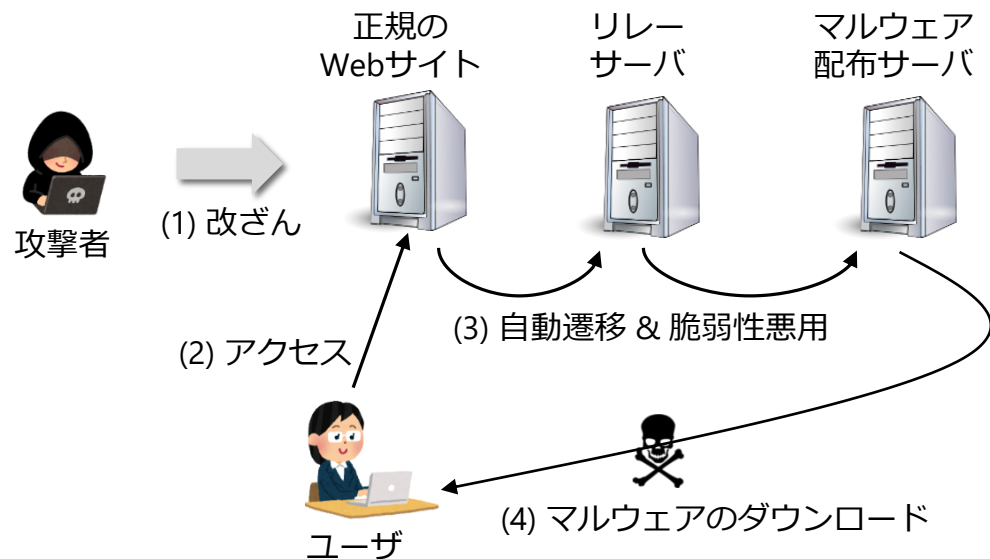


海賊版ソフトは非常に危険

- 違法サイトへのアクセスや海賊版ソフトの利用はリスクが高い
- マイクロソフトの調査結果（2017年）
 - 海賊版ソフトの92%にマルウェアが仕込まれていた
 - 海賊版ソフトを配布しているWebサイトには、ほぼ100%マルウェアが仕込まれていた
 - ・ ダウンロード／インストールが完了したと同時にマルウェアに感染（34%）
 - ・ 海賊版ソフトが“正常”にインストールされずに悪質なサイトへ誘導（31%）
 - ・ インストール後にセキュリティ対策ソフトを無効にする（24%）

Drive-by Download 攻撃

- Webページを閲覧ただけで攻撃が実行される
 - (1) 攻撃者は正規のWebサイトを改ざんして悪性コードを注入
 - (2) クライアントが正規のWebサイトにアクセス
 - (3) クライアントPCがマルウェア配布サーバに自動遷移
 - (4) 攻撃が成功したら，秘密裏にマルウェアがダウンロードされる
- ウェブブラウザなどの脆弱性が突かれることが多い



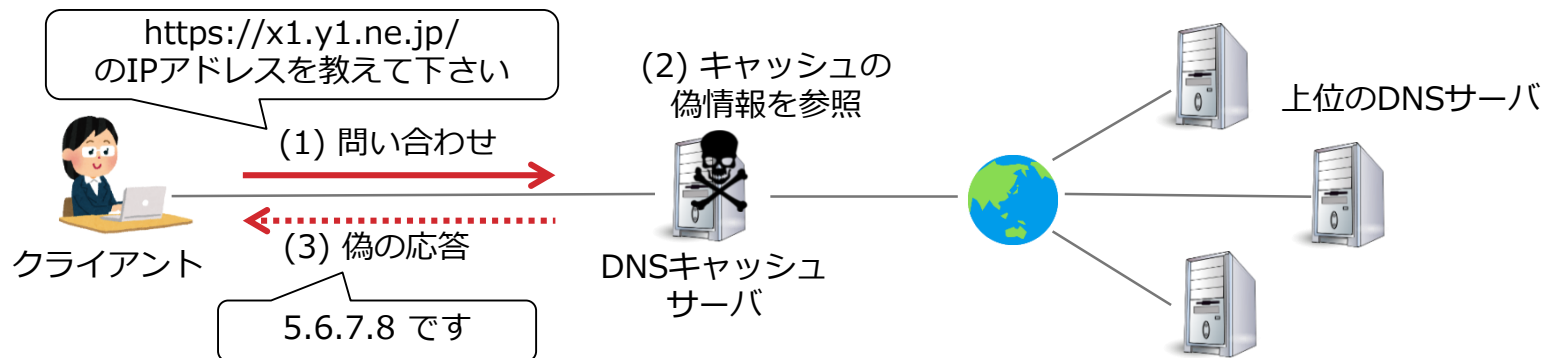
DNSキャッシュポイズニング

- DNS (Domain Name System)

- IPアドレスとホスト名の対応関係を管理し、クライアントからの問い合わせに応じて両者を相互に変換する仕組み
 - ・ 正引き：ホスト名からIPアドレスを調べる
 - ・ 逆引き：IPアドレスからホスト名を調べる
- 応答パケットの確認は16ビットの識別子IDで行う

- DNSキャッシュポイズニング

- DNSキャッシュサーバに偽のDNS情報をキャッシュとして蓄積させ、ホスト名とIPアドレスの対応を不正に変更する



DNSキャッシュポイズニング攻撃手法

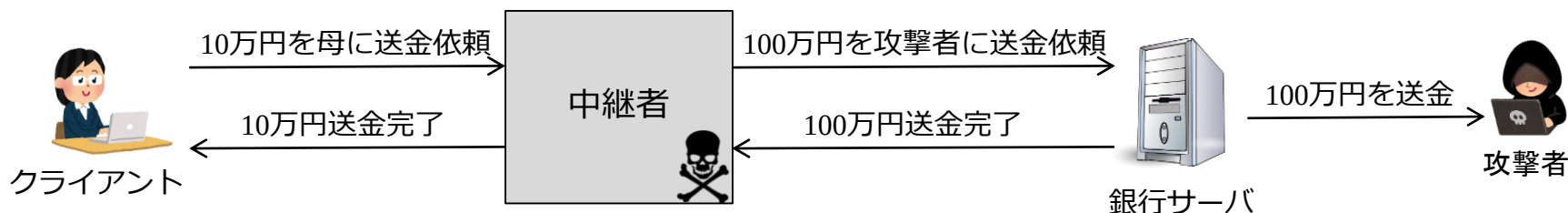
- DNSキャッシュポイズニングを実行する攻撃手法
 - (1) 攻撃者は、偽造したいドメイン名をDNSキャッシュサーバに問い合わせる
 - (2) DNSキャッシュサーバは、他のDNSサーバに問い合わせる
 - (3) 攻撃者は、他のDNSサーバからの応答より早く、偽の応答を行う
 - 識別子IDが一致した場合、攻撃が成功



中間者攻撃 (Man-in-the-Middle, MITM)

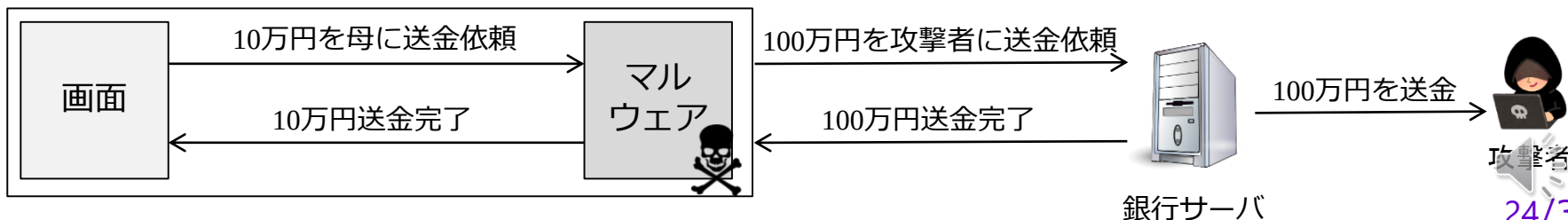
- 攻撃者が2人の当事者の間で交わされるメッセージを横取りして、間に別のメッセージを差し挟んで中継する
 - 通信の暗号化やワンタイムパスワードが破られる場合もある
- 発展形に「Man-in-the-Browser, MITB」がある
 - クライアント内で動作するため被害に気付きにくい

Man-in-the-Middle (MITM)



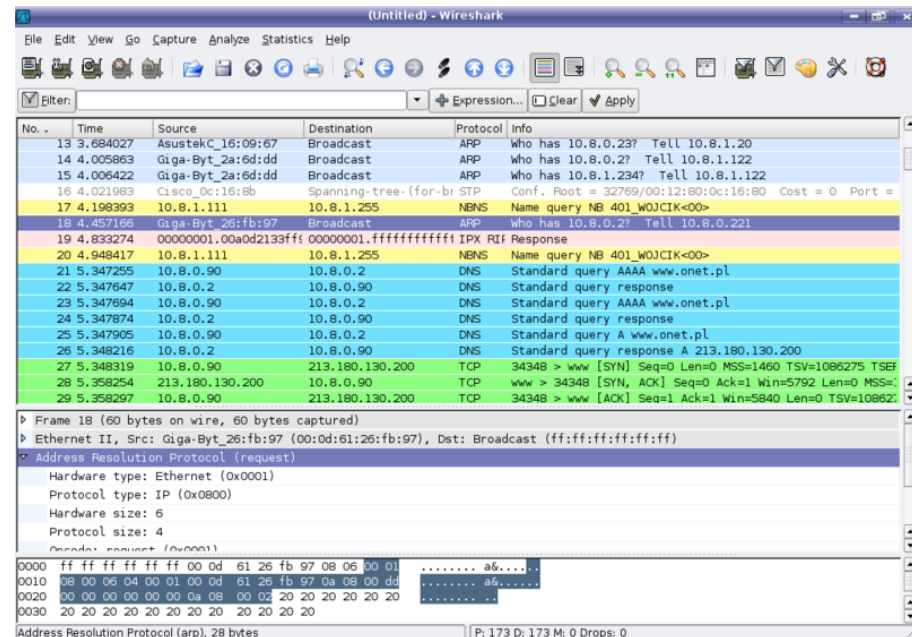
Man-in-the-Browser (MITB)

ブラウザ



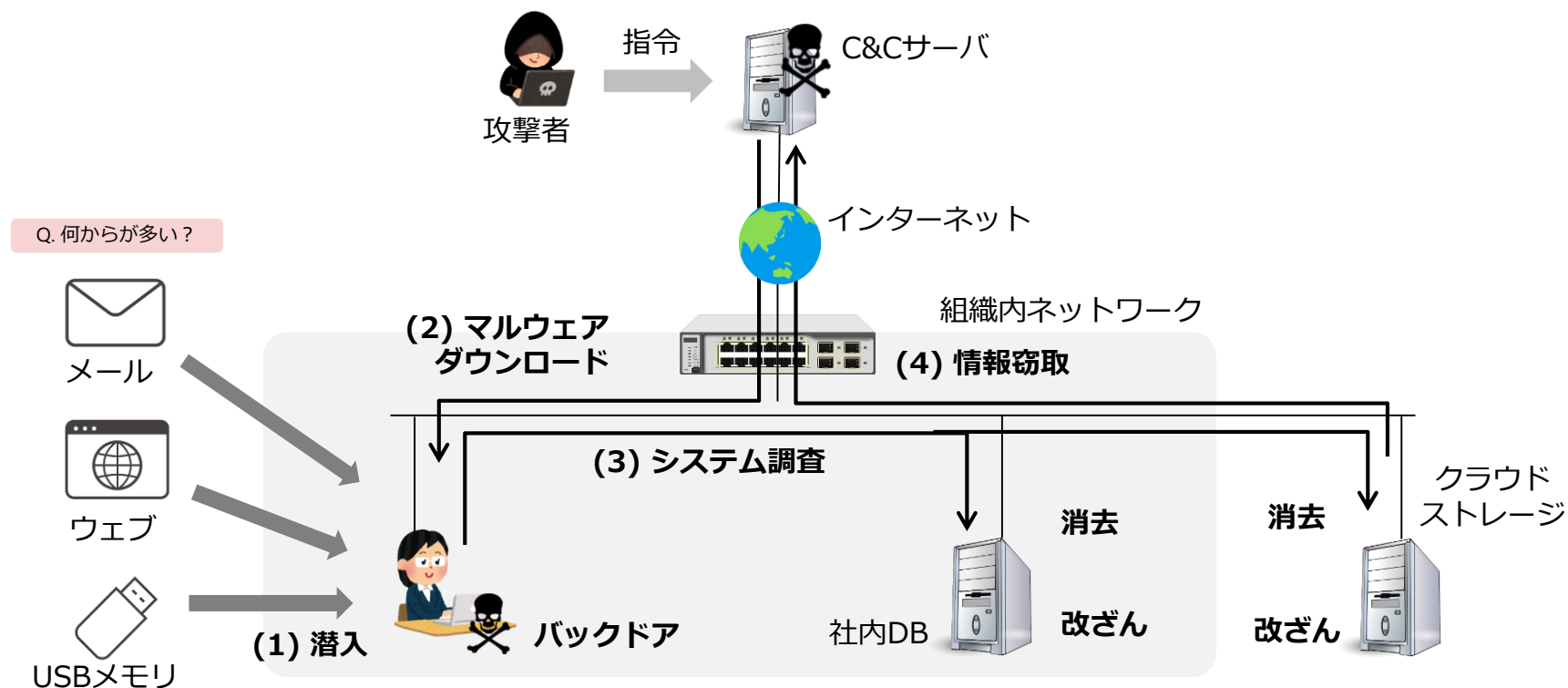
社内（LAN内）での盗聴

- スニファと呼ばれるネットワーク解析ツール
 - Wireshark（作成者はEtherealと同じ）
 - tcpdump
- 上位のスイッチングハブを流れるパケットを盗聴可能
- 対策
 - 通信の暗号化
 - e.g., SMTP/TLSの利用



標的型サイバー攻撃 (Advanced Persistent Threat, APT)

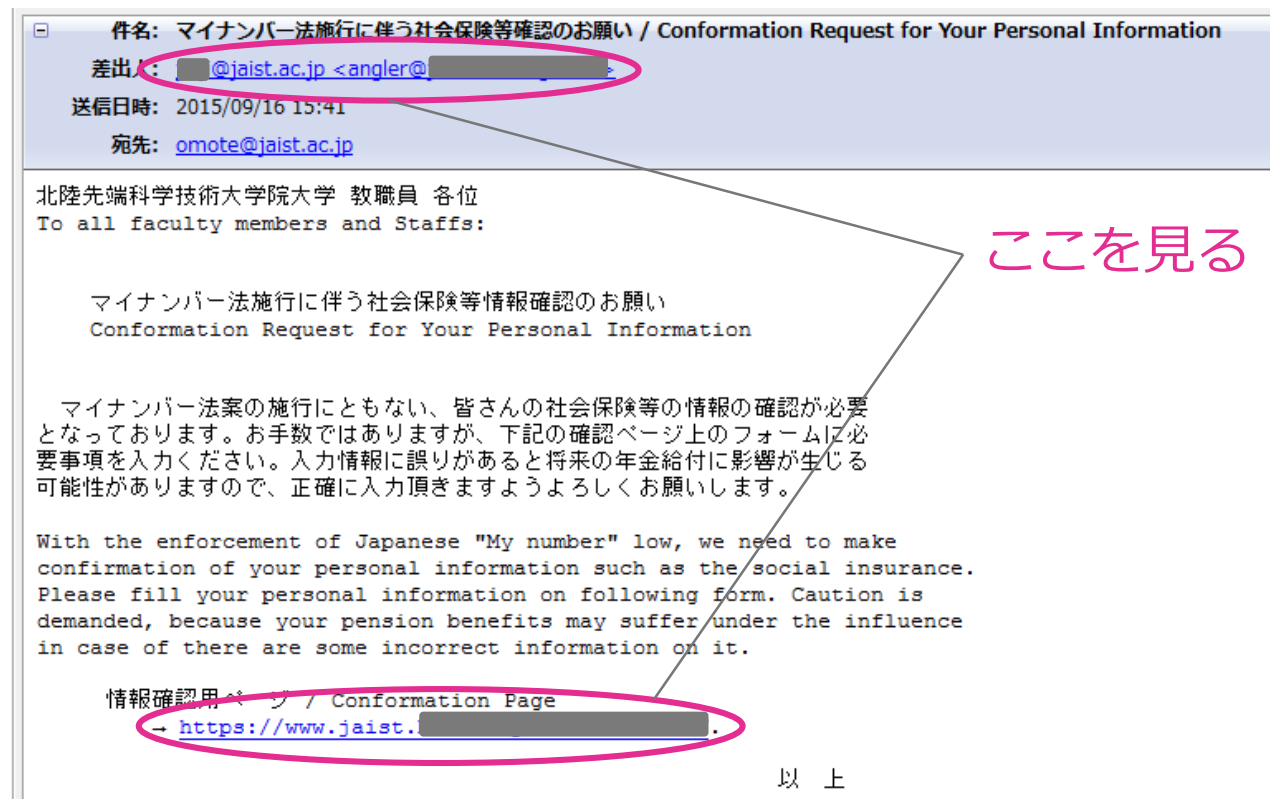
脆弱性を悪用し，複数の既存攻撃を組み合わせ，ソーシャルエンジニアリングにより特定企業や個人をねらい，対応が難しく執拗な攻撃（IPAによる定義）



標的型メールの例

- JAIST管理者を装う標的型メールの例

- 訓練に使用されたもの



過去の起きた筑波大学への標的型メール

- メールシステム（Active!mail）の管理者を装う
- 実際にアクセスした人 5 名ほど



アカウントの詳細を入力し、以下の更新

名前

ユーザーID

パスワード

再確認パスワード

部門

電話番号

アップデート

ファイアウォールの限界

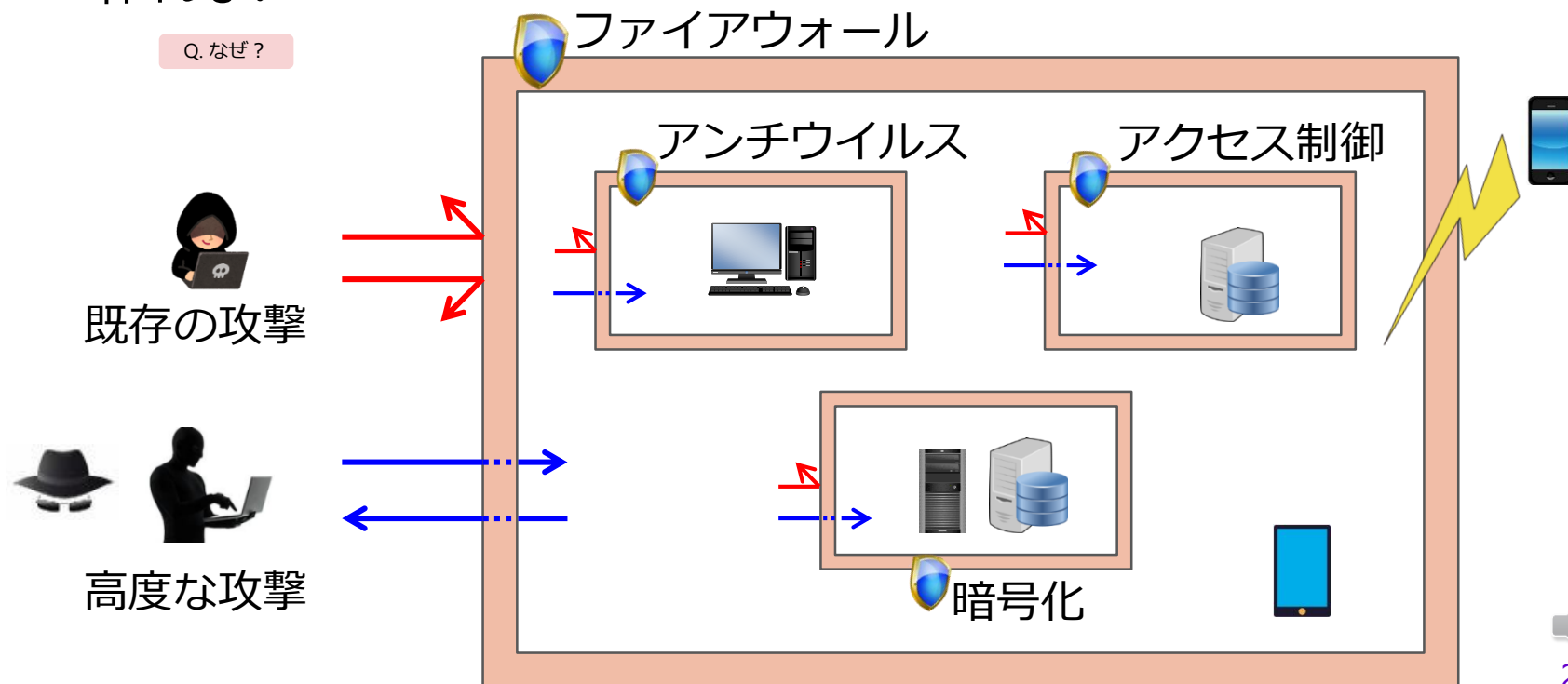
- 高度な攻撃が脅威

- 既存の防御を巧妙にすり抜けてくる（標的型メールなど）

- 利用形態の進化への対応が必要

- リモートアクセスやBYOD（Bring Your Own Device）のため防御壁を作れない

Q. なぜ？



ソーシャルエンジニアリング

- コンピュータやネットワークを利用せずに、人間の心理的な隙や行動のミスにつけ込んで秘密情報を盗み出す方法
- 電話によるなりすまし
 - 社員や取引先を名乗ってシステム管理者へ電話
 - 「緊急だからパスワードを教えてほしい」などと言う
- ピギーバック
 - ICカード等による入退室管理において、正規で入室するユーザの背後に密着して認証を受けずに入室する行為
- ショルダーハッキング
 - ノートPCの画面を肩越しに覗く行為
- ダンプスターダイビング／スカベンジング
 - ゴミ置き場のゴミの中から機密情報を盗む行為



公衆無線LANの脅威

出典：公衆無線 LAN 利用に係る脅威と対策 - IPA

- 盗聴（Webページ内容，メール本文など）
 - WPA3等で暗号化されていてもアクセスポイントでは復号可能
- なりすまし（MACアドレス偽造によるもの）
 - MACアドレスフィルタリングを使用した場合に起こりうる
- 悪意のAP
- 不正目的でのインフラ利用



自動車 (IoT) のセキュリティ

- コネクテッドカー (connected car)
 - ICT端末としての機能を有する自動車
 - 制御ネットワークであるCAN (Controller Area Network) を搭載
 - CANは, ECU (Electronic Control Unit) と車載LANで構成される自動車の制御ネットワーク
- CANへの攻撃事例
 - ワシントン大学のKohno教授らは, 診断用ポートを介してCANに侵入し, ブレーキ等の不正制御が可能であることを初めて実証 [S&P2010]
 - Millerらは, 脆弱性を突いてファームウェアを書き換え, 遠隔からCANメッセージを送信して不正制御を実証 [Defcon2015]
 - ・ フィアット, クライスラー, オートモービルズなどの大規模リコール
- CANの通信を安全にすることが目的

ネットワークカメラの脅威

- ネットワークカメラ（ライブカメラ）
 - 映像や音声をTCP/IPで流すことができ、サーバ機能を備えたカメラ
- Insecam
 - 世界中の監視カメラの映像を24時間リアルタイムで表示するサイト
 - パスワードによるアクセス制御が設定されていないインターネット接続された監視カメラが対象
- IoT機器におけるアクセス制御の意識が低い
 - 誰が管理するかに大きく依存
 - 公開サーバでのアクセス制御は常識
 - 台数が膨大で管理が行き届かないIoT機器特有の問題
 - 不要なtelnetのポートが空いていて、パスワードがデフォルトのまま

ビッグデータの脅威

- 保険・銀行

- クレジットカード記録が価値を持つ
- 購買行動・消費行動が分かれば保険やローンの優良顧客か推測可能

- マーケティング

- アメリカの小売大手Targetが、購買データ分析によって女性が妊娠したことを親よりも早く察知

- 雇用

- 部下が仕事を辞めるつもりかどうかを上司に知らせるソフトウェア
- どの従業員が予算を超過しそうかを予測できるプログラム
- 一部の企業では人材の採用や昇進の判断にビッグデータを活用

AIの脅威

- AIを活用したサイバー攻撃対策
 - 様々なシステムのログやイベントを統合的に分析することにより脅威に対処
 - 専門家の手動による分析では不可能な量の脅威を検知可能
- AIを活用したサイバー攻撃
 - 防御側が使用可能なら攻撃側も使用可能
 - 高度なスパイフィッシングが可能
 - 例えば、電子メールが監視された場合、その膨大なデータを解析して特定の人物宛のメッセージを自動で模倣
- AIを騙す攻撃（Adversarial Example）
 - 正しく判定できていた対象に、人が判別できないノイズ等を注入することで、判定器を誤判定させる攻撃